

Security Validation Report

Project: PrestaShop with ModSecurity WAF

Environment: Apache on Kali Linux

Objective

To secure the PrestaShop application using ModSecurity and validate that attacks are blocked while normal users can still log in and register.

What Was Implemented

Installed ModSecurity

Enabled OWASP Core Rule Set (CRS)

Activated blocking mode (SecRuleEngine On)

Monitored logs using modsec_audit.log

Attack Testing

SQL Injection Test

Payload used:

Copy code

?id=1' OR '1'='1

Result:

Blocked with 403 Forbidden

Logged in ModSecurity audit log

Protection working.

Login/Register Issue

Problem:

Login and registration pages were blocked (403 error)

Cause:

CRS misinterpreted PrestaShop's internal URL as a Remote File Inclusion (false positive).

Solution:

Created a scoped rule exclusion file.

Removed only specific rule IDs (931100 and 920350) for login/register endpoints.

WAF remained active for the rest of the site.

Result:

Login and registration work.

Malicious payloads are still blocked.

Final Validation Results

SQL Injection - Blocked

Login Access - Allowed

Registration - Allowed

WAF Active - Yes

Conclusion

The PrestaShop application is now protected by ModSecurity.

Attacks are blocked, and legitimate users can access authentication pages.

Security tuning was performed safely without disabling the WAF.